

FedCore Technologies

Enterprise Cybersecurity Strategy

FY26 Strategic Plan

Prepared by: Justin Maynor | Cybersecurity Strategy Lead

1. Executive Summary

FedCore Technologies is a government contractor supporting the U.S. Department of Defense (DoD) and Department of Homeland Security (DHS), operating a hybrid IT environment across roughly 250 employees and processing Controlled Unclassified Information (CUI). Given this mission and the sensitivity of the data involved, cybersecurity is not a support function — it is a condition of doing business with the federal government.

This strategy establishes a risk-driven, framework-aligned approach to protecting FedCore's people, data, and systems. It is built on four pillars: (1) a clear-eyed view of the organization's highest-impact risks, quantified in financial terms; (2) a governance structure that puts accountability for cybersecurity at the executive and board level; (3) adoption of the NIST Cybersecurity Framework (CSF) 2.0 to structure ongoing risk management; and (4) three near-term strategic priorities — Zero Trust, security awareness training, and network segmentation — backed by a \$35,000 annual investment plan and measurable KPIs.

The risk analysis shows that phishing and ransomware carry the highest annual loss exposure for FedCore, which directly informs where this year's budget and priorities are concentrated. Executing this strategy strengthens FedCore's compliance posture under NIST SP 800-171 and CMMC Level 2, reduces the likelihood and cost of a breach, and protects the trust FedCore has earned as a federal contractor.

2. Risk Landscape Overview

FedCore faces a threat landscape shaped by the sensitivity of the data it holds (CUI) and the customers it serves (DoD/DHS). Principal threat actors include nation-state Advanced Persistent Threats (APTs), cybercriminals conducting phishing and ransomware campaigns for financial gain, insider threats (intentional or accidental), and third-party/supply chain attackers.

A quantitative risk assessment was conducted using Single Loss Expectancy (SLE) and Annual Loss Expectancy (ALE) to rank risks by financial impact. The results are summarized below, ordered by ALE (highest financial impact first):

Risk / Threat	Single Loss Expectancy (SLE)	Annual Loss Expectancy (ALE)	Priority Rank
Phishing	\$225,000	\$900,000	1
Ransomware	\$300,000	\$600,000	2
Cloud Misconfiguration	\$375,000	\$362,000	3
Third-Party / Supply Chain Software	\$450,000	\$360,000	4
Vendor Outage	\$75,000	\$225,000	5
Distributed Denial of Service (DDoS)	\$30,000	\$180,000	6
Insider Data Theft	\$150,000	\$150,000	7
Zero-Day Exploit	\$600,000	\$120,000	8
Fire / Physical Disaster	\$900,000	\$90,000	9
Insider IP Theft	\$75,000	\$37,500	10

Phishing carries the single highest Annual Loss Expectancy (\$900,000), followed closely by ransomware (\$600,000). Because both are largely driven by credential compromise and human error, they are directly addressed by this strategy's top priorities — Zero Trust access controls and security awareness training — and by targeted budget allocations toward MFA, email security, and training (see Sections 5 and 6). Cloud misconfiguration and third-party/supply chain risk round out the top four and reinforce the need for continuous configuration monitoring and vendor security requirements.

3. Governance Structure

Cybersecurity accountability at FedCore is structured top-down, ensuring risk decisions are visible to leadership while day-to-day execution stays with dedicated security teams:

- **Board of Directors:** provides strategic oversight and reviews cybersecurity risk at the enterprise level.
- **CEO:** ensures cybersecurity strategy aligns with business objectives and provides the resources needed to execute it.
- **Chief Information Security Officer (CISO):** reports to the CEO and leads the organization's cybersecurity strategy end to end.
- **Security Operations Center (SOC), Security Engineering, and Governance, Risk & Compliance (GRC):** report to the CISO and collaborate to monitor threats, implement security controls, and manage compliance and risk.
- **Third-Party Vendors:** work alongside the cybersecurity team and are contractually required to comply with FedCore's security policies and standards.

This structure ensures that cybersecurity risk is owned at the Board level, resourced at the executive level, and executed by specialized teams — which is essential for an organization subject to CMMC and DFARS oversight.

4. Strategic Framework Selection

NIST Cybersecurity Framework (CSF) 2.0

FedCore has selected the NIST Cybersecurity Framework (CSF) 2.0 as its governing framework. NIST CSF was chosen because it is widely recognized, scales to organizations of any size or industry, and provides a structured approach to managing cybersecurity risk while aligning security objectives with business goals — an important fit given FedCore's federal contracting obligations under NIST SP 800-171 and CMMC Level 2, both of which are themselves built on NIST guidance. Using CSF's Govern, Identify, Protect, Detect, Respond, and Recover functions gives FedCore a common structure for maturing its program and demonstrating compliance to DoD/DHS auditors.

5. Top 3 Security Priorities

1. Implement a Zero Trust Security Model

- Reduces insider and external threats by removing implicit trust from the network.
- Strengthens access control across cloud and on-premises systems.

- Protects sensitive government data and CUI.

2. Strengthen Cybersecurity Awareness Training

- Reduces human error, the leading contributor to phishing-driven losses.
- Improves phishing detection and reporting by staff.
- Promotes a security-focused culture across all 250 employees.

3. Implement Network Segmentation

- Limits the spread of malware and ransomware across the environment.
- Protects critical systems, particularly those handling CUI.
- Improves incident containment and reduces blast radius during an incident.

6. Budget Overview

The following annual security investment plan directly supports the strategic priorities above and targets the highest-ALE risks identified in Section 2:

Security Investment	Annual Cost	Category	Justification / Strategic Alignment
Multi-Factor Authentication (MFA)	\$3,000	Software	Reduces risk of credential-based attacks (directly mitigates the #1-ranked phishing risk)
Backup and Disaster Recovery Solution	\$12,000	Service	Ensures critical business data can be restored after attacks or other disasters
Email Security Gateway	\$6,000	Software	Filters phishing emails, spam, and malicious attachments
Security Awareness Training	\$4,000	Training	Educates employees on cybersecurity attacks and risks; reduces human error
Endpoint Detection and Response (EDR)	\$10,000	Software	Detects, investigates, and responds to threats in real time
Total Annual Investment	\$35,000		

This \$35,000 annual investment is deliberately weighted toward the organization's top risk: MFA, the Email Security Gateway, and Security Awareness Training together total \$13,000 and directly target phishing and credential-based attacks (the #1-ranked risk by ALE), while the Backup/DR solution and EDR (\$22,000) address ransomware and broader detection/recovery needs (the #2-ranked risk). This allocation reflects the risk exercise finding that phishing and cloud-related exposure should be prioritized first when directing incremental security spend.

7. Policy Highlights

Remote Access Policy

Purpose: Ensure employees can securely access company resources while working remotely.

- Company-approved devices only, with Multi-Factor Authentication (MFA) required.
- VPN required for all remote connections; public Wi-Fi is prohibited unless tunneled through the VPN.
- Devices must maintain updated antivirus software and current security patches.

Password Management Policy

Purpose: Protect company accounts and sensitive information through strong authentication practices.

- Minimum 12-character passwords, combining uppercase, lowercase, numbers, and special characters.
- Password reuse is prohibited.
- MFA is required for all privileged and business-critical accounts.

Incident Response Policy

Purpose: Establish a structured process for responding to cybersecurity incidents to minimize damage and recover quickly.

- Suspected incidents must be reported immediately and compromised devices isolated.
- Incidents are investigated, contained, eradicated, and recovered from following a consistent process.
- Every incident is documented, with post-incident reviews conducted to improve future controls.

8. Metrics / KPIs

The following KPIs will be tracked to measure the effectiveness of this strategy and reported to the CISO and Board on a quarterly basis:

KPI / Metric	Target	Tied To
Phishing simulation click rate	< 5% of employees click per quarterly test	Awareness & Training Priority
MFA adoption rate	100% of privileged and business-critical accounts	Zero Trust Priority
Mean Time to Detect (MTTD)	< 4 hours for critical alerts	SOC Monitoring / IDPS
Mean Time to Respond (MTTR)	< 24 hours for high-severity incidents	Incident Response Policy
Security awareness training completion	100% of employees annually	Awareness & Training Priority
Critical systems segmented	100% of Tier-1 (CUI-handling) systems	Network Segmentation Priority
Critical vulnerability remediation SLA	Patched within 15 days of discovery	Vulnerability Management
Backup/DR restoration test success rate	100% success on quarterly test restores	Backup & DR Investment
NIST SP 800-171 / CMMC Level 2 control compliance	≥ 95% of controls satisfied	Compliance Posture